SIMATS ENGINEERING
ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking **COURSE CODE: ITA14**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Report Analysis
Questions

- A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system. **(20 Marks)**

Answer:

1. Interpretation of the Nmap Report

The scan (nmap -sS -sV -O 192.168.1.10) shows that the host is live and exposes three services. Version detection (-sV) and OS fingerprinting (-O) also reveal exact software and operating system details, which is valuable reconnaissance information for an attacker.

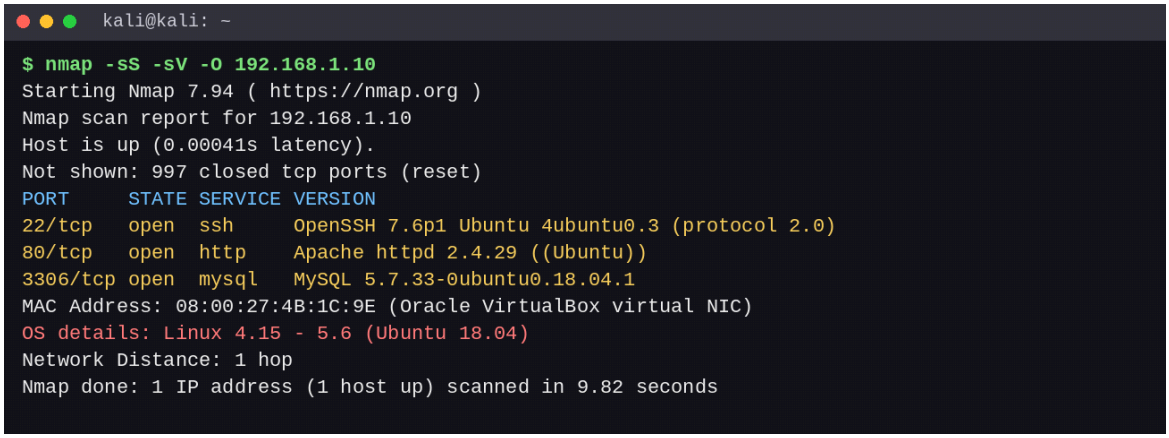


Figure 1: Sample Nmap scan output for 192.168.1.10 (illustrative)

- **22/tcp – SSH (OpenSSH):** remote administration channel; target for brute force and credential attacks, and outdated versions may have known CVEs.
- **80/tcp – HTTP (Apache):** unencrypted web service that exposes the web application attack surface (injection, XSS, misconfiguration, version banners).
- **3306/tcp – MySQL:** database reachable over the network; it should normally be accessible only from the application server.
- **OS and service versions:** allow the attacker to match each version to public CVEs and exploits.

2. Security Risks of the Identified Services

- **SSH (22):** brute-force and dictionary attacks, password spraying, default or weak credentials, root login enabled, outdated OpenSSH, and stolen private keys.
- **HTTP (80):** clear-text traffic allows sniffing and man-in-the-middle attacks on credentials and cookies; the web application may suffer from SQL injection, XSS, file inclusion, directory traversal, unrestricted file upload and exposed admin panels.
- **MySQL (3306):** brute-forcing of root or other accounts, empty/default passwords, unpatched vulnerabilities, data theft or destruction, and abuse of excessive privileges (such as FILE) leading to file access or code execution.

3. How an Attacker Could Exploit These Services

- **Enumeration:** use the banners and versions to search NVD and Exploit-DB for matching vulnerabilities.
- **SSH:** guess credentials with tools such as Hydra; on success the attacker gets a shell and attempts privilege escalation and lateral movement.
- **HTTP:** scan with Nikto or Burp Suite, exploit injection or upload flaws to get a web shell, dump the database or steal sessions.
- **MySQL:** try default or weak credentials remotely, dump user data and password hashes, or read files from the server.
- **Attack chain:** web flaw gives database credentials, database access gives password hashes or reused passwords, which then allow SSH login and full control of the server.



Figure 2: Possible attack chain across the exposed services

4. Recommended Security Measures

- **Firewall / network:** default-deny rules; block port 3306 from everyone except the application server (or bind MySQL to 127.0.0.1); restrict SSH to trusted IPs or a VPN/bastion host; deploy IDS/IPS (Snort/Suricata) to detect scans and brute force.
- **SSH hardening:** PermitRootLogin no, key-based authentication instead of passwords, MFA, Fail2ban for repeated failures, and keep OpenSSH updated.
- **Web server:** enable HTTPS (TLS 1.2/1.3) and redirect port 80 to 443, add HSTS and security headers, hide version banners, disable directory listing, remove default pages, use a WAF, and apply input validation with parameterised queries.
- **MySQL hardening:** run mysql_secure_installation, remove anonymous users and the test database, use strong unique passwords, least-privilege accounts, disable remote root login, enable TLS and audit logging.
- **Patch management and monitoring:** regularly update the OS and all services, run vulnerability scans (Nessus/OpenVAS), centralise logs in a SIEM, alert on failed logins and unusual queries, keep backups, and re-scan after changes.

Conclusion: The open ports are not wrong in themselves, but their exposure creates a large attack surface. Least exposure, strong authentication, encryption, patching and monitoring greatly reduce the risk.

- A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.**(20 Mark).**

Answer:

1. Interpretation of the Campaign Report

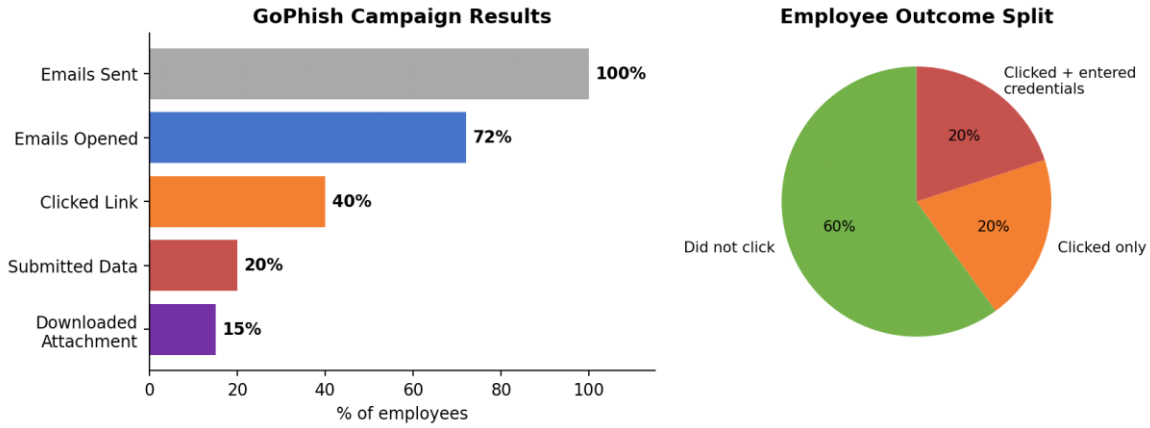


Figure 3: GoPhish campaign results for ABC Technologies Pvt. Ltd. (illustrative)

- **40% clicked the link:** almost half of the employees cannot reliably recognise a malicious link, so the initial-access step of a real attack would succeed at scale.
- **20% entered credentials:** one in five handed over usernames and passwords, so an attacker could log in to email, VPN or internal systems. This is the most serious result. Half of those who clicked also submitted data, which shows that the fake login page was convincing and the URL was not verified.
- **Several downloaded the attachment:** untrusted files were opened without suspicion; in a real attack this could deliver malware, ransomware or remote access tools.

2. Security Weaknesses Demonstrated

- **Lack of security awareness:** employees do not notice spoofed senders, mismatched URLs, spelling errors or unusual requests.
- **Susceptibility to social engineering triggers:** urgency, authority, fear and curiosity successfully pushed users to act without thinking.
- **Poor verification habits:** links were not hovered over, domains not checked and requests not confirmed through another channel.
- **Unsafe attachment handling:** files were downloaded and opened without scanning.
- **Weak technical controls:** the phishing email reached inboxes (inadequate filtering), and credential theft is damaging when MFA is not enforced.
- **Weak reporting culture:** no easy habit or tool for reporting suspicious emails.

3. Recommendations

A. User Awareness Programs

- Mandatory induction and annual security awareness training with real examples of phishing, smishing, vishing and spear-phishing.
- Regular simulated phishing campaigns (GoPhish) with an immediate learning page for users who fail, and tracking of click and report rates over time.
- Role-based training for high-risk groups such as HR, finance, executives and IT support.
- Short micro-learning (posters, newsletters, quizzes) and a "Report Phishing" button; reward reporting rather than punishing mistakes.

B. Email Security Controls

- Implement SPF, DKIM and DMARC (quarantine/reject policy) to stop domain spoofing.
- Use an email gateway with spam/phishing filtering, URL rewriting, time-of-click link checking and attachment sandboxing.
- Block or strip risky attachments (.exe, .js, .iso, macro-enabled Office files) and tag external emails with a warning banner.
- Enforce multi-factor authentication on all accounts, and use endpoint protection (EDR/antivirus) and DNS/web filtering to block malicious domains.

C. Organisational Policies

- Email security and acceptable use policy defining how to handle unknown links, attachments and requests.
- Password and access policy: unique strong passwords, password managers, least-privilege access and immediate credential reset when phishing is suspected.
- Incident response procedure: report immediately, isolate affected accounts/machines, reset credentials and investigate.
- Verification policy for sensitive actions (payments, credential resets, data requests) using call-back or a second approver.
- Review campaign metrics periodically against targets (for example, click rate below 10%) and report them to management.



Layered (defence-in-depth) protection against phishing

Figure 4: Layered defence against social engineering attacks

Conclusion: People are the weakest link, but the risk can be reduced with a layered approach combining continuous training, strong email and authentication controls, and clear policies.

- A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure..**(10 Marks)**

Answer:

1. Interpretation

A zone transfer (dig axfr example.com @ns1.example.com) is meant only for synchronising primary and secondary DNS servers. The report shows that the DNS server answers AXFR requests from any host, so the whole zone file is disclosed. This is a DNS misconfiguration and an information disclosure vulnerability.

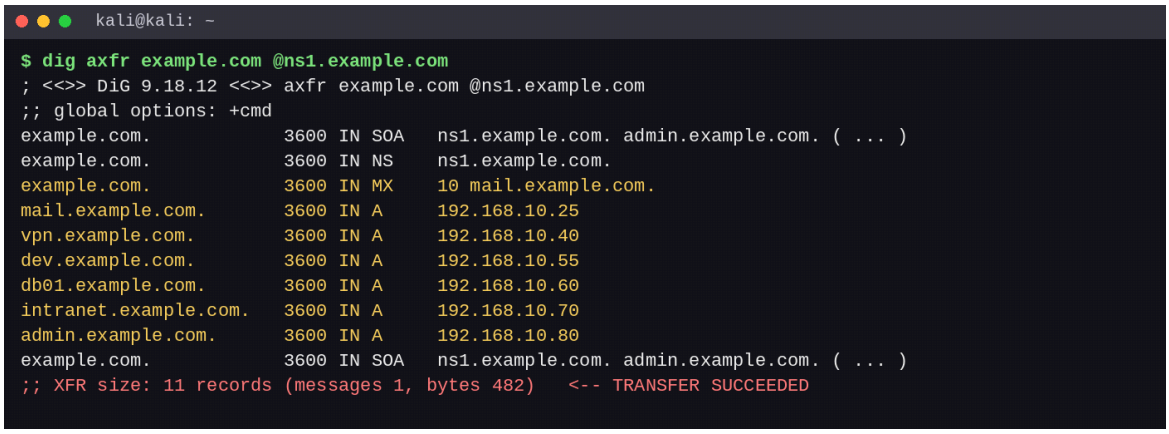


Figure 5: Sample successful DNS zone transfer using Dig (illustrative)

2. Security Implications of the Exposed Information

- **Internal hostnames:** names such as dev, vpn, admin, db01 and intranet reveal the naming scheme and sensitive systems.
- **IP addresses:** A/AAAA records map the network and live hosts without noisy scanning.
- **Mail servers (MX):** identify mail infrastructure to target for phishing, relay abuse or exploitation.
- **Other records (NS, CNAME, TXT, SRV):** reveal third-party services, SPF/verification data and service locations such as LDAP or Kerberos.
- **Forgotten or test systems:** development and legacy servers are often unpatched and weakly protected.

3. How Attackers Could Exploit These Findings

- Footprinting: build a complete map of the target in seconds and pick the weakest hosts to scan with Nmap and exploit.
- Targeted attacks on exposed development, staging, VPN or admin portals, including credential attacks.
- Phishing and social engineering using real hostnames, mail servers and naming conventions to look convincing.
- Subdomain takeover when CNAME records point to deprovisioned external services.
- Planning DNS spoofing or cache poisoning, and finding internal-only names that should never be public.

4. Best Practices to Secure the DNS Infrastructure

- **Restrict zone transfers:** allow AXFR only to authorised secondary servers by IP (BIND: allow-transfer { trusted-IP; };) and authenticate transfers with TSIG keys.

- **Split-horizon DNS:** keep internal records on internal servers and publish only required public records.
- **Minimise records:** remove stale and test entries, avoid descriptive names that reveal function, and audit the zone regularly for dangling records.
- **Harden servers:** keep DNS software updated, disable recursion for external clients, rate-limit responses and limit port 53 with a firewall.
- **DNSSEC and monitoring:** use DNSSEC to protect integrity, and log DNS queries and alert on AXFR attempts.
- **Re-test:** confirm with dig axfr from an external host that the transfer is now refused.

Conclusion: An open zone transfer gives attackers a ready-made blueprint of the organisation. Restricting AXFR, separating internal and external DNS and monitoring are simple, low-cost fixes that greatly reduce reconnaissance exposure.

Code of Conduct:

I Hasthavaram sanjay reddy (192372056)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:
Hasthavaram sanjay reddy

RUBRICS FOR CALCULATION

Report Analysis					
Criteria	**Weightage (%)**	**Level 4 (Exemplary)**	**Level 3 (Proficient)**	**Level 2 (Developing)**	**Level 1 (Beginning)**
Report Analysis and Interpretation	25%	Accurately interprets the security report, identifies all key findings, and explains their significance with excellent technical understanding.	Correctly interprets most findings with minor omissions or inaccuracies.	Identifies only some findings and provides limited interpretation.	Unable to interpret the report or identify key findings.
Identification	25%	Correctly	Identifies	Identifies only	Fails to identify

of Security Risks and Vulnerabilities		identifies all security risks, vulnerabilities, and possible attack vectors with clear technical justification.	most risks and vulnerabilities with minor errors.	a few risks with limited technical explanation.	major risks or vulnerabilities.
Application of Cybersecurity Concepts and Countermeasures	30%	Applies appropriate ethical hacking concepts and recommends comprehensive, practical, and technically sound countermeasures.	Recommends suitable countermeasures with minor technical gaps.	Provides limited or partially appropriate recommendations.	Recommendations are inappropriate, incomplete, or missing.
Technical Communication and Documentation	20%	Response is well-organized, technically accurate, clearly presented, and uses appropriate cybersecurity terminology throughout.	Response is organized and understandable with minor documentation or presentation issues.	Response lacks clarity, organization, or contains several technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.